Data Classification & Handling Guidelines

Policy ID: POL-SEC-007 | Classification: Internal | Owner: Information Security

Version: 4.1
Effective: 2024-03-01
Supersedes: 3.5

1 Purpose and Scope

1.1 Purpose

1.1.1 Define data classification levels and handling requirements
1.1.2 Establish accountability for data protection
1.1.3 Ensure regulatory compliance (GDPR, CCPA, SOX)

1.2 Scope

1.2.1 Applies to all employees, contractors, and third parties
1.2.2 Covers all data formats: electronic, paper, verbal
1.2.3 Includes data at rest, in transit, and in use

2 Data Classification Levels

Classification	Label	Description & Handling Requirements
Public	GREEN	Information approved for public release. No restrictions on distribution.
Internal	YELLOW	Business information for internal use. Share only with employees who need it.
Confidential	ORANGE	Sensitive business data. Requires encryption and access controls. NDA required for third parties.
Restricted	RED	Highly sensitive data (PII, financial, health). Strictest controls. Encryption mandatory. Access logged and audited.

KEY POLICY STATEMENT

All data must be classified at creation. Unclassified data defaults to CONFIDENTIAL.
Data owners are responsible for accurate classification and periodic review.
Violations may result in disciplinary action up to and including termination.

3 Security Requirements Checklist

Mandatory Requirements

- [x] Encrypt data at rest using AES-256 (Required)
- [x] Encrypt data in transit using TLS 1.2+ (Required)
- [x] Implement access logging (Required)
- [x] Quarterly access reviews (Required)
- [x] Annual security training (Required)
- [x] Incident response plan (Required)

Optional Enhancements

- [ ] Hardware security modules (HSM)
- [x] Data loss prevention (DLP) tools
- [ ] Advanced threat protection
- [ ] Behavioral analytics
- [x] Zero-trust architecture
- [x] Automated compliance scanning

4 Handling Procedures

4.1 Storage

4.1.1 Restricted data: encrypted storage only (approved systems list in Appendix A)
4.1.2 Confidential data: secure file shares with access controls
4.1.3 Retention per Records Management Policy (POL-REC-002)

4.2 Transmission

4.2.1 Email: use encryption for Confidential and above
4.2.2 File transfer: SFTP or approved secure platforms only
4.2.3 No sensitive data via instant messaging or SMS

4.3 Disposal

4.3.1 Electronic: secure deletion using approved tools
4.3.2 Paper: cross-cut shredding for Confidential and above
4.3.3 Media: physical destruction with certificate